

BUSINESS CONTINUITY AND DISASTER RECOVERY POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Business Continuity and Disaster Recovery Policy
Document ID	POL-BCP-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC7.5 and CC9.1, and GDPR Article 32. It is written for a ten-person team whose largest continuity risk is people, not infrastructure.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 WHAT MUST BE RECOVERABLE6

6 PEOPLE6

7 TECHNOLOGY7

8 TESTING7

9 RECORDS.....7

10 EXCEPTIONS.....8

11 REFERENCE.....8

12 DOCUMENT POLICY HISTORY.....8

1 Overview and Purpose

PromptHalo Technologies (“the Company”) runs on AWS with its infrastructure defined in code. Rebuilding the technology is the part the Company is good at. The part that needs writing down is what happens when the one person who knows something is unavailable.

This Policy therefore spends most of its length on people and very little on data centres. It says what the Company must be able to recover, how quickly, who does it when the usual person cannot, and how that is tested.

2 Scope

This Policy covers the systems and information needed to deliver the Company's service and to meet client commitments: the AWS estate, the code in GitHub, the information held in Google Workspace, and the people who operate them.

It does not cover physical premises. The Company has none, and a distributed team is a continuity strength rather than a gap.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. Every critical responsibility has a named alternate. Where the Company has only one person with a given capability, the alternate is the person who can reach the systems and call for help, and the gap is recorded as a risk rather than left implicit. [SOC 2: CC9.1, CC1.3]
5. The Security Officer's designated alternate is the CEO, who holds break-glass access under the Access Control Policy. Saying so plainly is better than leaving it to be worked out during an incident. [SOC 2: CC9.1, CC6.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Alternate** — the named person who performs a critical responsibility when the usual owner cannot.
3. **Business impact analysis** — the record of which activities matter most, what they depend on, and how long they can be interrupted.

- 35 4. **Confidential information** — information classified Confidential or Restricted under the Data
36 Classification Policy, including customer data.
- 37 5. **Control** — an activity, automated or manual, performed on a defined cadence that produces
38 evidence it occurred.
- 39 6. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
- 40 7. **Information Security Steering Committee** — the Company's oversight body for information
41 security. At the Company's current size, the Committee comprises the CEO, and every reference
42 in this policy to a decision, approval, review or report of the Committee is satisfied by a dated
43 written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2,
44 CC1.3]
- 45 8. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of
46 the Company.
- 47 9. **Recovery point objective** — the maximum data loss the Company accepts for a given system,
48 expressed as a period.
- 49 10. **Recovery time objective** — the time within which the Company intends to restore a given
50 system after an interruption.
- 51 11. **Security Officer** — the individual accountable for day-to-day operation of the security program.
- 52 12. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that
53 requires risk reassessment.
- 54 13. **Subservice organization** — a third party whose controls the Company relies upon and which is
55 carved out of the Company's report.

56 **5 What Must Be Recoverable**

- 57 1. A short business impact analysis records the activities that matter, what each depends on, who
58 performs it, and how long it can be interrupted before a client commitment is at risk. One page
59 covers the Company. [SOC 2: CC9.1]
- 60 2. Recovery time and recovery point objectives are set for the production service, the code
61 repository and the information in Google Workspace. They are stated as what the Company
62 intends and can demonstrate, not as what would sound reassuring in a proposal. [SOC 2: CC9.1]
- 63 3. The analysis is refreshed annually and whenever the service or a client commitment changes
64 materially. [SOC 2: CC9.1, CC3.4]

65 **6 People**

66 At the company of this size, continuity is mostly a question of who else can do it.

- 67 1. Each critical responsibility is listed with its owner and a named alternate. The list is short and sits
68 alongside the incident contact list so there is one place to look. [SOC 2: CC9.1, CC1.3]

2. Where no genuine alternate exists, that concentration is recorded as a risk in the register with a compensating measure — documented runbooks, a retained external responder, or a decision to accept it. An unrecorded single point of failure is the finding; a recorded one is a position. [SOC 2: CC9.1, CC1.5]
3. Alternates hold or can obtain the access needed to act, through break-glass credentials rather than standing privilege. [SOC 2: CC9.1, CC6.3]

7 Technology

1. Infrastructure is defined in code, so recovery is a rebuild rather than a restoration from memory. The continuity strategy holds no unique state outside recoverable systems, which is what the Cloud Platform Standard exists to guarantee. [SOC 2: CC9.1, CC8.1]
2. Backups cover the production data stores and are held in an account separate from the workloads they protect, encrypted, with a retention that meets the recovery point objective. [SOC 2: CC9.1, CC6.7]
3. Google Workspace and GitHub are relied on as subservice organizations for their own resilience. The Company's exposure is its own data in them, which is covered by export or backup rather than by assuming the provider will never fail. [SOC 2: CC9.1, CC9.2]

8 Testing

1. A restore test is performed annually: one database snapshot and one storage prefix restored into an isolated account, with the start and end times recorded and compared to the stated recovery time objective. An untested backup is an assumption. [SOC 2: CC9.1]
2. A continuity walkthrough is held annually, in the same sitting as the incident tabletop were convenient. It checks that alternates know they are alternates and that the access they would need works. [SOC 2: CC9.1, CC7.5]
3. Where a test does not meet the objective, the objective is corrected or the arrangement is — but the result is recorded either way. A test that quietly fails and is repeated until it passes is not evidence. [SOC 2: CC9.1]
4. Tests also run when something changes materially: a new critical dependency, a change of provider, or a departure that removes an alternate. [SOC 2: CC9.1, CC3.4]
5. A scheduled test or review that is not performed on time is itself recorded as a deficiency in the plan of action and escalated, rather than quietly rescheduled. With annual cadences there is one occurrence in a twelve-month period, so a missed date is the whole control rather than a delay. [SOC 2: CC4.2, CC9.1]

9 Records

1. The business impact analysis with recovery objectives. [SOC 2: CC9.1]
2. The critical responsibility list with owners and named alternates. [SOC 2: CC9.1]

3. Annual restore test records with timings against the objectives. [SOC 2: CC9.1]
4. The annual walkthrough record. [SOC 2: CC9.1, CC7.5]
5. Concentration risks recorded in the risk register with their compensating measures. [SOC 2: CC9.1, CC1.5]

10 Exceptions

Where a requirement of this Policy cannot be met — most commonly because no genuine alternate exists for a capability — the position is recorded by the Accountable Party with the compensating measure and a review date and carried as a risk. Where no exceptions are in force, that is recorded affirmatively at the annual review.

11 Reference

1. SOC 2 Trust Services Criteria, Security category [CC7.5, CC9.1]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. STD-CLD-001 Cloud Platform Standard [SOC 2: CC9.1]
4. POL-AC-001 Access Control Policy [SOC 2: CC6.3]
5. POL-IRP-001 Incident Response Policy [SOC 2: CC7.5]
6. POL-RSK-001 Risk Management Policy [SOC 2: CC3.2]
7. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
8. EU General Data Protection Regulation, Article 32

12 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release